Summary Notes: Database Security

• Database Security - Summary Notes**

• Target level: Secondary (grades 9-12)*

•

Overview

• Database security keeps the information in a computer system safe.

• It makes sure that **only the right people** can see or change the data and that the data is **always available** when needed.

• The three ideas that guide every security decision are called the **CIA triad** - **C**onfidentiality, **I**ntegrity, and **A**vailability.

• Schools protect databases with passwords, encryption, access-control rules, backups, and activity monitoring.

•

1. The CIA Triad

| Pillar | What it means | Simple school-room example |

|--------|---------------|----------------------------|

| **Confidentiality** | Data is hidden from anyone without permission. | A teacher's test key is locked in a drawer so only the teacher can open it. |

| **Integrity** | Data stays correct and unchanged unless an authorized person edits it. | A grade book that automatically records who changed a grade and when. |

| **Availability** | Authorized users can reach the data whenever they need it. | The school's online portal works even if one server fails. |

• The three pillars support each other.

• Example:* Encrypted backups keep the data secret **and** can be restored quickly, helping both confidentiality and availability.

•

2. Authentication & Authorization

• **Authentication** - proving who you are.

• Methods: passwords, fingerprint/face scan, two-factor codes (a code sent to your phone).

• **Authorization** - deciding what you are allowed to do after you're authenticated.

• Example: A student logs in (authenticated) and can **view** their own grades but cannot **edit** anyone's grades (authorized).

• **Why keep them separate?**

• You can change what a user can do (authorization) without forcing a new password (authentication).

• **Role-Based Access Control (RBAC)** - permissions are tied to roles, not to each person.

• *Roles*: "Teacher", "Student", "Admin".

• A teacher role can edit class lists; a student role cannot.

•

3. Encryption & Hashing

| Concept | Plain-language definition | Everyday analogy |

|---------|---------------------------|------------------|

| **Encryption** | Scrambles readable data (plaintext) into unreadable data (ciphertext). Only someone with the right key can unscramble it. | Like locking a diary with a secret code; only the person who knows the code can read it. |

| **Symmetric encryption** (e.g., AES) | The same secret key is used to lock **and** unlock the data. | One key that both you and your friend keep safe. |

| **Asymmetric encryption** (e.g., RSA) | Uses a public key to lock data and a private key to unlock it. | You post a locked box (public key) that anyone can drop a note into, but only you have the key to open it (private key). |

| **Hashing** | Turns data into a fixed-size "digital fingerprint." It cannot be turned back into the original data. | Like a fingerprint that uniquely identifies a person but can't be used to recreate the person. |

| **Salted hash** | Adds random data (a "salt") before hashing a password, making each hash unique even for the same password. | Adding a secret spice to each recipe so two identical dishes still taste different. |

• **Where it matters**

• **At rest** - data stored on disks or backups (e.g., encrypted files).

• **In transit** - data moving between a web app and the database (e.g., TLS/SSL).

•

4. Access-Control Models & the Principle of Least Privilege

• **Discretionary Access Control (DAC)** - owners decide who can see or change their data.

• *Example:* A teacher gives a teaching assistant read-only access to a class roster.

• **Mandatory Access Control (MAC)** - the system enforces strict rules that users cannot change.

• Used for highly classified information (e.g., government records).

• **Role-Based Access Control (RBAC)** - permissions are attached to roles, not individuals.

• Simplifies management; add a new teacher -> assign the "teacher" role.

• **Least Privilege** - give each user only the rights they need to do their job.

• *Good:* A student can view only their own grades.

• *Bad:* Giving every student the ability to delete tables would break this rule.

•

5. Common Threats & Defenses

| Threat | What happens | Simple defense |

|--------|--------------|----------------|

| **SQL Injection** | An attacker inserts malicious code into a database query, gaining read/write access. | Use **prepared statements** (parameterized queries) that separate code from data. |

| **Network attacks** (e.g., sniffing, DDoS) | Data is intercepted or the server is overwhelmed. | Firewalls and intrusion-detection systems block unwanted traffic. |

| **Insider misuse** | A trusted user abuses their access. | Enforce least privilege and monitor activity with audit logs. |

| **Mis-configured cloud services** | Open ports or default passwords expose data. | Regular configuration reviews and strong default settings. |

| **Phishing** | Users are tricked into giving away credentials. | Teach students to recognize suspicious emails and use 2FA. |

• **Input validation** - always check that user-entered data matches the expected format (numbers only, proper length, etc.). This stops many injection attacks.

•

6. Backup, Recovery, Auditing & Physical Security

• **Backup** - make copies of the database (full or incremental).

• **Recovery drill** - practice restoring from a backup to ensure the process works quickly.

• **Auditing** - record who accessed what data and when; keep logs immutable (cannot be changed).

• **Physical security** - lock server rooms, use CCTV, control temperature, and protect against fire or theft. Software alone can't stop a thief who walks away with the hardware.

•

7. Key Takeaways

1. **CIA triad** is the foundation: keep data secret, correct, and available.

2. **Authentication** proves identity; **authorization** decides what that identity can do.

3. **Encryption** protects data at rest and in transit; **hashing** secures passwords.

4. Use **RBAC** and the **least-privilege** rule to limit damage from compromised accounts.

5. Regular **backups**, tested **recovery plans**, and protected **audit logs** are essential for bouncing back after an incident.

•

8. Conclusion

Database security is a layered effort that mixes technology, policies, and good habits. By understanding how confidentiality, integrity, and availability work together, students can see why strong passwords, encrypted connections, and limited permissions matter in everyday apps. Knowing common threats like SQL injection and how to defend against them prepares young learners to use technology responsibly and keep school data safe.

•

9. Quick Glossary

• **Ciphertext** - scrambled data that looks meaningless without a key.

• **Plaintext** - readable, original data before encryption.

• **TLS/SSL** - protocols that encrypt data traveling over the internet.

• **Prepared statement** - a database query where placeholders are used for user data, preventing injection.

• **Salt** - random data added to a password before hashing to make each hash unique.

•

10. Quiz - 10 Multiple-Choice Questions

1. **What does the "C" in the CIA triad stand for?**

A) Control B) Confidentiality C) Connectivity D) Consistency

2. **Which of the following is an example of authentication?**

A) Giving a student read-only access to grades. B) Checking a fingerprint before login. C) Backing up the database. D) Encrypting the data file.

3. **In role-based access control, which role would most likely have permission to edit class lists?**

A) Student B) Teacher C) Guest D) Parent

4. **What is the main purpose of hashing a password?**

A) To hide the password while it travels over the network. B) To create a reversible secret key. C) To store a one-way fingerprint of the password. D) To compress the password for faster login.

5. **Which statement best describes "least privilege"?**

A) Give every user admin rights to avoid permission errors. B) Assign each user only the rights needed for their tasks. C) Allow users to change their own permissions. D) Disable all user accounts when not in use.

6. **A prepared statement helps prevent which attack?**

A) Phishing B) DDoS C) SQL injection D) Man-in-the-middle

7. **What does "encryption at rest" protect?**

A) Data while it is being typed into a form. B) Data stored on a hard drive or backup. C) Data moving across the internet. D) Data displayed on a screen.

8. **Which access-control model is set by the system and cannot be changed by individual users?**

A) DAC B) MAC C) RBAC D) ACL

9. **Why are backup recovery drills important?**

A) They make the backup files larger. B) They test that data can be restored quickly when needed. C) They delete old backups automatically. D) They encrypt the backup files.

10. **Physical security of a database server includes all EXCEPT:**

A) Locked server room B) CCTV cameras C) Strong passwords D) Fire-suppression system

• Answers: 1-B, 2-B, 3-B, 4-C, 5-B, 6-C, 7-B, 8-B, 9-B, 10-C.*